

# **Manual 40 — CJIS Security Policy Controlled Implementation**

**\*\*Controlled baseline:\*\*** FBI CJIS Security Policy Version 6.1 dated June 25, 2026, subject to release-time reverification.

**\*\*Boundary:\*\*** FBI policy requirements, state CSA implementation requirements, security addenda/agreements, contracts, companion materials, and organization-specific practices remain distinct source layers.

**\*\*Release rule:\*\*** reverify the current FBI CJIS Security Policy and applicable CSA requirements at candidate freeze.

## **Chapter 01 — Purpose, scope, and source hierarchy**

Establish the controlled CJIS source hierarchy, applicability method, ownership, change control, and evidence index. Do not treat examples, resource-center material, or local practice as independently binding FBI policy text.

## **Chapter 02 — Applicability and CJI boundaries**

Determine whether systems, users, locations, interfaces, and service providers access, process, transmit, store, or support Criminal Justice Information. Record inclusion, exclusion, and ambiguity decisions with source-linked rationale.

## **Chapter 03 — Agency, CSA, and responsibility model**

Define agency, CSA, contracting, hosting, support, and provider responsibilities for the specific operating model. Maintain responsibility matrices, agreements, escalation paths, and authority evidence.

## **Chapter 04 — Governance and accountability**

Assign accountable executives, security, privacy, legal, operations, architecture, procurement, HR, and service-owner roles. Maintain approvals, exceptions, risk decisions, management-review evidence, and corrective-action ownership.

## **Chapter 05 — System and data inventory**

Inventory CJI-related applications, infrastructure, endpoints, interfaces, cloud services, administrators, data stores, backups, and third parties. Maintain owners, data flows, system boundaries, dependencies, and change history.

## **Chapter 06 — Security-policy mapping**

Map applicable CJIS requirements to organization controls, procedures, technical configurations, evidence objects, and testing methods. Preserve traceability to the exact controlled policy version.

## **Chapter 07 — Personnel screening and suitability**

Define screening, authorization, onboarding, status-change, suspension, and offboarding controls for personnel with relevant CJI access or support duties. Maintain evidence of completion, decisions, exceptions, and periodic review.

## **Chapter 08 — Security awareness and role training**

Deliver role-based CJIS security training aligned to access, administrative, operational, and incident responsibilities. Maintain curricula, completion, competency checks, remediation, and refresh triggers.

## **Chapter 09 — Physical protection**

Define physical access, visitor, facility, workspace, device, media, and environmental safeguards for applicable CJI environments. Maintain access records, facility reviews, exceptions, and corrective actions.

## **Chapter 10 — Identity and account lifecycle**

Control account request, approval, provisioning, modification, periodic review, suspension, and termination. Maintain identity evidence, account ownership, privileged flags, review results, and revocation timing.

## **Chapter 11 — Advanced authentication and MFA**

Apply authentication controls appropriate to user, device, network, remote-access, and privileged scenarios under the current CJIS baseline and applicable CSA requirements. Record technical design, exceptions, testing, and compensating controls where permitted.

## **Chapter 12 — Privileged access**

Restrict privileged access to authorized personnel and approved administrative paths. Maintain privileged-role inventories, justifications, session controls, monitoring, review evidence, and break-glass procedures.

## **Chapter 13 — Least privilege and access control**

Implement role-appropriate authorization, segregation of duties, need-to-know controls, periodic recertification, and access-change governance. Maintain access matrices, approvals, exceptions, and test evidence.

## **Chapter 14 — Encryption in transit**

Protect CJI in transit across applicable internal, external, remote, wireless, cloud, and third-party connections using approved cryptographic mechanisms. Maintain protocol baselines, certificate/key evidence, configuration checks, and exceptions.

## **Chapter 15 — Encryption at rest**

Protect stored CJI where required by the applicable CJIS and CSA control context. Maintain storage inventories, encryption decisions, technical settings, key dependencies, exceptions, and validation evidence.

## **Chapter 16 — Cryptographic and key governance**

Define ownership, generation, storage, rotation, revocation, recovery, backup, and retirement controls for cryptographic keys and certificates supporting CJI protection. Maintain inventories, custodians, change records, and test results.

## **Chapter 17 — Logging and audit records**

Capture security-relevant events for CJI systems, administrative activity, authentication, access, configuration change, and incident investigation as applicable. Maintain logging scope, retention rationale, access controls, review evidence, and exceptions.

## **Chapter 18 — Monitoring and time synchronization**

Maintain monitoring, alerting, time synchronization, event correlation, and escalation practices sufficient to support security operations and evidentiary integrity. Retain monitoring coverage, source clocks, alert handling, and review evidence.

## **Chapter 19 — Media protection**

Control creation, marking, storage, transport, reuse, sanitization, and disposal of media containing CJI. Maintain chain-of-custody, sanitization evidence, destruction records, exceptions, and periodic checks.

## **Chapter 20 — Mobile, remote, and wireless access**

Govern mobile devices, remote access, telework, wireless connectivity, and portable systems based on documented applicability and risk. Maintain approved configurations, user authorization, device controls, connection methods, monitoring, and exception records.

## **Chapter 21 — Network and security architecture**

Document segmentation, trust boundaries, security zones, external connections, management networks, administrative paths, and protective technologies supporting CJI environments. Maintain diagrams, configuration baselines, approvals, and review records.

## **Chapter 22 — Vulnerability, patch, and configuration management**

Define vulnerability identification, prioritization, remediation, patching, secure configuration, change control, and exception handling for CJI systems and dependencies. Maintain scan/test evidence, remediation tracking, approved baselines, and risk decisions.

## **Chapter 23 — Incident response and reporting**

Integrate CJI security events into incident intake, triage, containment, evidence preservation, escalation, reporting, recovery, and lessons learned. Maintain incident records, notification decisions, timelines, communications, and corrective actions.

## **Chapter 24 — Cloud and service-provider governance**

Assess cloud, managed, hosted, SaaS, support, and infrastructure providers for CJI applicability, responsibility allocation, access, data location, security, monitoring, subcontracting, incident, retention, and exit requirements. Maintain due diligence, contracts, architecture, approvals, and oversight evidence.

## **Chapter 25 — Outsourcing, security addenda, and agreements**

Maintain required agreements, security addenda, contracting controls, responsibility statements, and compliance evidence for external parties supporting CJI environments. Distinguish FBI policy, CSA implementation, contractual duties, and organization controls.

## **Chapter 26 — Backup, resilience, and continuity**

Protect backups and recovery capabilities for CJI systems consistent with security, availability, integrity, and access requirements. Maintain backup inventories, restoration tests, recovery objectives, alternate-processing decisions, and corrective actions.

## **Chapter 27 — Data retention and disposal**

Define retention, archival, deletion, sanitization, legal hold, and disposal rules using applicable CJIS, records, legal, contractual, and agency requirements. Do not present the CJIS Security Policy as a universal records-retention schedule.

## **Chapter 28 — Audits and assessments**

Plan and execute internal reviews, technical testing, evidence validation, external/CSA assessments, and remediation tracking. Maintain scope, samples, findings, severity, ownership, due dates, retest evidence, and closure decisions.

## **Chapter 29 — Corrective actions and exceptions**

Govern findings, corrective actions, temporary deviations, compensating measures, risk acceptance, expiration, and reapproval. Maintain root cause, owner, target date, evidence, approvals, and closure validation.

## **Chapter 30 — Metrics and management review**

Track meaningful indicators such as access-review exceptions, overdue patches, privileged-account findings, training completion, incidents, unresolved audit findings, provider issues, and change-watch status. Management review should document decisions, resources, escalations, and improvement priorities.

## **Chapter 31 — Localization, provenance, and release evidence**

Freeze controlled EN/es-419/pt-BR publication candidates before final exact-candidate review. Bind DOCX/PDF identities to SHA-256 hashes and preserve structure, parity, accessibility, rendered-page, source-version, workflow-security, and staging evidence.

## **Chapter 32 — Implementation roadmap and release-time reverification**

Implement in phases: applicability and inventory; governance; people and access; architecture and cryptography; logging and monitoring; endpoint/media/remote controls; providers; incident/resilience; assurance; and continual improvement. Immediately before publication, reverify the current FBI CJIS Security Policy version and applicable CSA implementation requirements; publication remains sequential after Manual 39.